ICFAI Foundation for Higher Education
(Deemed-to-be University under Section 3 of the UGC Act, 1956)

IcfaiTech
Faculty of Science & Technology (FST)

CS415:Ethical Hacking

ICFAI Foundation for Higher Education
(Deemed-to-be University under Section 3 of the UGC Act, 1956)

IcfaiTech
Faculty of Science & Technology (FST)

UNIT-I

An Introduction to Ethical Hacking: Security Fundamental, Security testing, Hacker and Cracker, Descriptions, Test Plans-keeping It Legal, Ethical and Legality

The Technical Foundations of Hacking: The Attacker's Process, The Ethical Hacker's Process, Security and the Stack

Cyber Attack?

A cyber attack is an attempt to **steal, damage or destroy** information or systems.

Types of Cyber Attacks:

- **Phishing** – Fake emails to steal passwords
- **Malware** – Malicious software (viruses, worms, etc.)
- **DDoS Attack** – Flooding servers to shut them down
- **Man-in-the-Middle Attack** – Intercepting communication between two parties

Cyber security?

Cybersecurity is the practice of **protecting systems, networks and data** from digital attacks.

It's about **defending** against threats like hacking, malware, phishing, ransomware, etc.

Why it's important?

To protect personal data, financial systems and critical infrastructure (banks, hospitals, etc.)

Hacking:

Hacking is the process of gaining access to a system illegally or the process of finding weaknesses in the system to gain unauthorized access to the system, network, or, any data to perform harmful activities such as login to an account without permission

Ethical hacking ?

Ethical hacking is the legal and professional practice of testing computer systems, networks and applications.

- This is done to find and fix security weaknesses before malicious hackers can exploit them.
- It involves using hacking techniques, but with permission and a positive goal.
- The aim is to protect digital assets and improve overall cybersecurity.

Ethical hacking

- Ethical hacking is by various means protecting the data and securing the information from illegal access or from hacking.
- It involves activities for an authorized attempt to access a computer system, protecting exploitable weaknesses in the system and resources, and carrying out all the actions to prevent attempts of malicious attackers.

- Ethical hackers, often called **white-hat hackers**, are trained professionals who simulate real-world cyberattacks.
- Their job is to think like attackers, simulate real-world threats and identify weak points that could pose a risk to sensitive information and infrastructure.

Ethical hacking plays a crucial role in:

- Strengthening an organization's security posture.
- Ensuring compliance with cybersecurity standards.
- Building resilience against cyberattacks.
- Uses hacking techniques with prior approval from the system owner.

Types of hackers

Depending upon the activities performed by hackers they are categorized into :

- White hat hackers
- Black hat hackers
- Gray hat hackers

White hat hackers

- These types of hackers are also called ethical hackers or pen testers.
- They are considered cyber security professionals certified to hack computer systems and organization networks and their main aim is to protect against cyber security attacks.
- They use their skills and experience to find vulnerabilities in systems.
- They find loopholes in systems and drawbacks in network security and resolve them before cyber criminals can find them.

Black hat hackers

- They are called cyber criminals who use security vulnerabilities of computer systems as entry points and exploit them for malicious reasons like financial fraud, violating the privacy, stealing sensitive information, etc.
- They use their advanced technical knowledge and skills for wrong intentions.
- They can also compromise web applications, software, or systems to alter the way it functions.
- They can hack social media profiles to ruin anyone's reputation

Gray hat hackers

- They are a mix of both white hat and black hat hackers.
- They identify weaknesses in the system without the owners permission. But their intention *is not bad*.
- They report their findings of issues and vulnerabilities to the owner and sometimes demand money to fix it.
- Though these kinds of hackers are not bound to any ethical hacking policies, they do not put someone at risk

Black hat hacker vs white hat hacker vs gray hat hacker

- A black hat hacker accesses the data in an unauthorized way, compromises a system without permission, steals data for financial gain, or damages the system.
- A white hat hacker takes permission before security testing and alerts the organization about the same.
- A gray hat hacker might attempt to compromise the system without permission but it informs the organization about its loopholes and allows them to fix it. Though they do not use their access for malicious purposes or bad intentions they compromise security systems without permission.

Hackers?

Type	Description
White Hat	Ethical hackers – help secure systems (Good guys)
Black Hat	Criminal hackers – break into systems illegally
Grey Hat	In between – may violate rules but not for personal gain

Hacker vs. Cracker

Hacker	Cracker
Can be ethical (white hat)	Always malicious
Tests systems legally	Breaks security illegally
Helps fix vulnerabilities	Destroys or steals data

Key aspects of Ethical Hacking

These aspects ensure that ethical hacking remains structured, legal and focused on improving cybersecurity.

Reporting: Ethical hackers report back to the organization with the results of the tests.

Permission-Based: This permission becomes necessary to differentiate their job from criminal hacking jobs

Objective: The main goal is to find the holes before hostile attackers can penetrate them. This includes discovering system, application, and network vulnerabilities that an attacker could exploit.

Methodology: Ethical hackers perform these steps using a variety of tools and techniques, similar to criminal hackers. It includes scanning for vulnerabilities testing to break in, and accessing control measures available.

Importance of Ethical Hacking

Ethical hacking contributes significantly to contemporary cybersecurity, ethical hackers are able to identify and address vulnerabilities before they are exploited by simulating the strategies and tactics utilized by cybercriminals. This proactive methodology serves to:

Enhance Security: Identify and address flaws to stop data breaches and cyberattacks.

Compliance: Meet security standards set by the industry and regulatory requirements.

Management of risk: Assess and reduce potential threats to the assets of the organization

Occurrence Reaction: Enhance the company's capacity to respond to security incidents and recover from them.

Types of Ethical Hacking

Depending on the focus of the security testing, ethical hacking can be broken down into a number of different categories:

Hacking the network: involves testing the infrastructure of the network in order to find flaws in the protocols, configurations, and devices of the network

Hacking Web Applications: Centers around distinguishing shortcomings in web applications, for example, SQL injection or cross-website prearranging (XSS) weaknesses

Hacking the system: Targets working frameworks and programming to find security defects that could be taken advantage of.

Social Designing: attempts to manipulate individuals into revealing confidential information or performing actions that could compromise security, putting the human element to the test.

Hacking into wireless networks: involves identifying potential dangers in wireless communications and evaluating the security of wireless networks.

Types of Ethical Hackers

Ethical hacking is to scan vulnerabilities and to find potential threats on a computer or network. An ethical hacker finds the weak points or loopholes in a computer, web application or network and reports them to the organization. So, let’s explore more about Ethical Hacking step-by-step.

These are various types of hackers:

- White Hat Hackers (Cyber-Security Hacker)
- Black Hat Hackers (Cracker)
- Gray Hat Hackers (Both)
- Blue Hat hackers
- Green Hat Hackers
- Red Hat Hackers.

The 6 Different Types of Hackers

Black Hat Hackers: Bad hackers who use cyber attacks to gain money or to achieve another agenda.

These hackers penetrate systems without permission to exploit known or zero-day vulnerabilities.

White Hat Hackers: Ethical hackers who protect your systems from black hat hackers.

Penetrate the system with the owner's permission to find and fix security vulnerabilities and mitigate cyberattacks.

Grey Hat Hackers: Hackers who cruise the line between being good and bad. Penetrate systems without permission but typically don't cause harm.

Draw attention to vulnerabilities and often offer a solution to patch them by charging fees.

Red Hat Hackers: Hackers who use cyber attacks to attack black hat hackers.

Their intentions are noble, but these hackers often take unethical or illegal routes to take down bad hackers.

Blue Hat Hackers: Hackers who seek to take personal revenge, or outside security professionals that companies hire to test new software & other products to find vulnerabilities prior to release.

Green Hat Hackers: Newbie hackers who are learning to hack.

They're often not aware of the consequences of their actions & cause unintentional damage without knowing how to fix it.

Security Fundamentals

These are the **basic principles of cybersecurity** and are vital for ethical hackers to understand what needs to be protected.

✅ **Confidentiality**

- Ensures that information is only accessible to authorized users.
- Prevents data leaks and spying.

Example: Encrypting a password or using a login system to access sensitive files.

✅ **Integrity**

- Ensures data is accurate and unmodified.
- Protects against unauthorized changes.

Example: Using file checksums or digital signatures to ensure no tampering has occurred.

✅ **Availability**

- Ensures systems and data are available when needed.

Example: Using backups or redundancy systems to keep a website online during a power failure or DDoS attack.

Security Testing

Security testing is the process of finding and fixing vulnerabilities in systems, applications, or networks **before hackers do**.

- Security Testing is a type of Software Testing method that ensures security of software systems and applications.
- That means to verify whether software system and application are free from vulnerabilities, risks, threats that may cause a data loss.
- Security testing of any system is the process of finding all possible weaknesses and loopholes of the system which might cause confidential data loss and results into the reputation which is in the hands of the employees or outsiders of the Organization.

Purpose

- To identify **loopholes** or **weak spots**.
- To ensure the system is **resilient against attacks**.
- To verify **compliance with security policies**.

Types of Security Testing

Vulnerability Scanning

•Uses automated tools (like Nessus or OpenVAS).
•Finds known security holes in systems.
•It uses automated software to scan a system for known vulnerability signatures

Penetration Testing (Pentesting)

•Simulates real-world attacks.
•Ethical hackers actively try to break into the system.
•It involves simulation of an attack from a malicious hacker.
•It also consists of system analysis to identify possible vulnerabilities.
•Example: Trying SQL injection on a login page.

Security Audits

•Manual inspection of code, configurations, or policies.
•Checks compliance and documentation.
•It contains an internal inspection of Applications and Operating Systems for security weaknesses. An audit can be ensured via line by line inspection of code

Risk Assessment

•Analyzes the probability and impact of potential threats.
•Helps prioritize which areas need the most protection.

Ethical Hacking

•Combination of the above using **legal and authorized methods**.
•Goal: **Find vulnerabilities before real hackers do**.

Descriptions (Terminologies)

Term	Meaning
Exploit	Code used to take advantage of a vulnerability
Payload	Malicious code delivered during an attack
Zero-Day	Unknown vulnerability with no fix
Firewall	Blocks unwanted traffic
IDS/IPS	Detects/prevents intrusions

Test Plans – Keeping It Legal

Ethical hacking must **follow a structured test plan** to avoid breaking the law.

✅ What should a test plan include?

- Scope: What is allowed to be tested?
- Timeframe: When will tests be done?
- Tools: What tools will be used?
- Permissions: Written legal approval from the owner

Always get signed legal consent before testing any system!

Ethics and Legality

- **Ethical Hacking = Legal hacking with permission**

  Always follow the **Code of Conduct**:
  Get authorization
  Report all findings
  Do not misuse access

- **Cyber Laws to Know**:

  IT Act 2000 (India)
  GDPR (Europe)
  CFAA (USA)

ICFAI Foundation for Higher Education
(Deemed-to-be University under Section 3 of the UGC Act, 1956)

IcfaiTech
Faculty of Science & Technology (FST)

TECHNICAL FOUNDATIONS OF HACKING

System hacking refers to the activity of searching for and taking advantage of weaknesses in a target system for unauthorized access, privilege escalation and data tampering or stealing.

Phases of System Hacking

System hacking usually occurs in an organized fashion, normally following the lifecycle of an ethical hacker. The most important phases are:

1. Reconnaissance

Gathering information on the target system (e.g., IP addresses, operating systems, open ports).

Tools: Nmap, Whois, Google Dorks.

2. Scanning

Vulnerability identification in the target system (e.g., open ports, services, misconfigurations).

Tools: Nessus, OpenVAS, Nikto.

Phases of System Hacking

3. Gaining Access

Illicit access to the system using vulnerabilities.

Techniques: Password cracking, exploiting software vulnerabilities, social engineering.

4. Maintaining Access

Guaranteed ongoing access to the system (e.g., installing backdoors, rootkits).

Tools: Metasploit, Netcat.

5. Clearing Tracks

Erasure of attack traces to avoid detection.

Techniques: Log deletion, timestamp manipulation.

Phases of Ethical Hacking

- **Preparation and planning**: Characterize the extent of the test, acquire fundamental authorizations, and accumulate data about the objective framework.
- **Reconnaissance**: Gather in-depth data about the target system, including information about its network structure, IP addresses, and potential security holes.
- **Scanning**: Scan the target system using a variety of tools and methods to look for vulnerable services, open ports, and vulnerabilities.
- **Gaining Access**: Attempt to gain access to the system by mimicking potential real-world attacks by taking advantage of identified vulnerabilities.
- **Maintaining Access:** Test the capacity to keep up with access inside the framework and survey ingenuity components that could be utilized by assailants.
- **Reporting and Analysis:** Produce a comprehensive report to the organization, document findings, and offer suggestions for reducing vulnerabilities.

Benefits of Ethical Hacking

Ethical hacking has advantages that go beyond just enhancing security, They consist of:

- **Preventing Data Breach:** Organizations can avoid costly data breaches by identifying vulnerabilities before attackers do.
- **Protecting Private Information:** safeguards vital data from misuse and unauthorized access.
- **Enhancing the System's Resilience:** It makes applications and systems stronger and more resistant to attacks.
- **Developing Trust**: Demonstrates a commitment to data security and improves the company's reputation.

Security and the Stack

Layer	Responsibility	Protocols/Ports	Potential Attacks
Application	Interface for user and applications to communicate over network	HTTP, FTP, Telnet, SMTP, DNS, SSH, SNMP	- Password capture- DNS spoofing- Enumeration- Session hijacking
Host-to-Host (Transport)	Reliable or unreliable delivery of data between hosts	TCP, UDP	- DoS (Denial of Service)- Session hijacking- Port scanning
Internet (Network)	Routing, IP addressing, and delivery	IP, ICMP, ARP	- Routing attacks- IP spoofing- Man-in-the-middle (MITM)- Fragmentation attacks
Network Access (Link/Physical)	Moving data over physical media (cables, WiFi)	Ethernet, PPP, SLIP	- MAC address spoofing- ARP poisoning- Physical tampering